SkillWallet MCP Server

Comprehensive Operational, Performance & Security Report

Production endpoint review | MCP JSON-RPC 2.0 over HTTP POST

Audit date: October 29, 2026

Target endpoint	Protocol	Operational status	Security status
https://globalapi.skillwallet.digital/mcp	MCP JSON-RPC 2.0 over HTTP POST	29 / 29 tools reported operational	CRITICAL RISK - plaintext password exposure

Report handling note

Confidential security report. This PDF is based on the audit text supplied in the conversation and does not independently validate the reported tests. Sensitive identity values have been masked in this distribution copy: the student email and student ID are partially redacted, and no password value is reproduced. Treat the source system and any related logs as potentially exposed until remediation is confirmed.

At a glance

29	2	1	7
Unique tools reported operational	Slow modes above 2 seconds	Critical credential exposure	Security findings discussed

Executive Summary & Audit Overview

The supplied audit reports successful execution of 29 MCP tools, with two modes of **get_course_topic_stats** exceeding the 2-second threshold. The most urgent finding is that **get_student_profile** reportedly returns an actual plaintext password along with personal data and an internal connection token. This should be handled as a security incident, not merely a profile-schema cleanup.

Other reported issues include unauthenticated execution of course-content endpoints, token acceptance in query parameters, raw internal exceptions returned to clients, write tools accepting empty arguments, and blocked CORS preflight. Recommended immediate actions are credential rotation, removal of sensitive fields from profile responses, and stricter gateway and write-schema validation.

Counting clarification: the report states 29 unique tools, while the matrix contains 30 operation rows because get_course_topic_stats is listed separately for topic-level and course-level modes.

Audit scope

The supplied report describes an end-to-end evaluation of tool execution, latency, and security controls on the production MCP endpoint. Its scope includes live student records and read/write tool behavior.

Identity field	Value reported in source
Student name	Chiranjeevi Madem
Email	ch**********@gmail.com (masked)
Student ID (sub)	6993f4...ead (partially redacted)
Role / status	student; fresher; adult
Plan / balance	Free tier; tokenBalance: 0
Purchases	17 records (courses and capstone projects)

Key results

- Operational coverage: all 29 unique tools are reported functional in the supplied test run.
- Performance: only two operation modes exceeded 2 seconds; both use get_course_topic_stats.
- Security: plaintext credential exposure in get_student_profile is the top-priority issue.
- Validation: source content is treated as supplied audit data, not independent proof of live-system behavior.

Immediate security posture: rotate the affected account credential, remove sensitive attributes from API responses, review access logs, and confirm whether other users or records were exposed.

2. Slow Tools Performance Analysis (> 2 Seconds)

Across the 29 unique tools, the supplied measurements identify two slow operation modes. The source attributes both to separate, multi-stage MongoDB aggregation pipelines.

Operation	Key parameter	Latency	Reported bottleneck	Optimization proposed
get_course_topic_stats Topic-level mode	topic_id = ...	3,429-5,624 ms 3.4-5.6 s	Deep 8-activity and diagnostic pipeline. Scans attempts across micro-assessment, flashcards, matching, this-or-that, drag-rank, spot-error, teach-back, and debate. Calculates prior topic completion sequence and Socratic recommendations.	Add compound index { student_id: 1, topic_id: 1 }. Persist a pre-calculated activity summary on the student-topic record rather than recomputing attempts on read.
get_course_topic_stats Course-level mode	course_id = ...	3,414 ms 3.4 s	Course-wide rollup iterates across chapters, lessons, and topics to calculate completion percentage, pacing velocity, and assessment averages.	Add compound index { student_id: 1, course_id: 1 }. Incrementally update course completion in Purchases when a topic completes instead of scanning the full curriculum tree.

Reported request and aggregation path

Tool request topic_id or course_id	Student scope filter records	MongoDB aggregation attempts or curriculum tree	Derived statistics completion, velocity, averages	Response 3.4-5.6 seconds

The source reports the other 27 unique tools responding in under 1 second, generally averaging 12-180 ms. This performance statement reflects the supplied measurements and should be re-run under representative production load before establishing an SLA.

3. Security Vulnerabilities & Design Assessment

CRITICAL - Plaintext password exposure: the source says get_student_profile returned a plaintext password field named orginalPassword. Do not reproduce or circulate the password value. Treat the credential as compromised until changed and its use reviewed.

3.1 CRITICAL: Plaintext Password and Sensitive PII in get_student_profile

CRITICAL

Finding: The source reports a direct MongoDB document dump without field projection. Exposed fields included orginalPassword (actual plaintext password; value redacted here), mobile, address, addressLine1, addressLine2, pincode, and linkedinToken (reported value: "connection").

Recommended remediation: Apply an explicit allow-list response schema or strict projection. Exclude orginalPassword, passwordOtp, mobileOtp, access tokens, and unrelated personal data. Hash passwords with Argon2id or bcrypt, never store plaintext. Rotate the credential, inspect logs, and assess the exposure scope.

3.2 INFORMATIONAL: Public tools/list Availability

INFORMATIONAL

Finding: tools/list reportedly succeeds without an Authorization header and returns all 29 tool names and schemas. The source assesses this as standard MCP discovery behavior; private tool execution is reported to remain authenticated.

Recommended remediation: Keep public discovery only if intentional. Confirm tools/call and all private data paths enforce authentication and authorization independently.

3.3 HIGH or LOW: Public Course Content Endpoints

HIGH if paid

Finding: get_course_outline, get_activity_grounding_material, and get_lesson_grounding_content reportedly execute without Authorization. Severity depends on whether the content is paid or access-controlled.

Recommended remediation: Verify content licensing and access requirements. Enforce authenticated purchase/entitlement checks for paid materials.

3.4 MEDIUM: Query Parameter Authentication

MEDIUM

Finding: POST /mcp?token= reportedly authenticates requests. URL tokens can be captured in proxy logs, CDN analytics, monitoring, or browser history.

Recommended remediation: Accept credentials through Authorization: Bearer only. Reject query-string tokens and scrub any already recorded tokens from logs.

3.5 MEDIUM: Internal Exceptions Leaked

MEDIUM

Finding: Calling get_module_progress with empty arguments reportedly returned a raw Python missing-argument exception.

Recommended remediation: Validate arguments at the gateway and return JSON-RPC error -32602 (Invalid params). Log details server-side with correlation IDs; do not return stack or function internals to clients.

3.6 MEDIUM: Empty-Argument Writes Create Junk Records

MEDIUM

Finding: save_activity_evaluation({}), save_learning_conversation({}), and handle_guided_learn({}) reportedly accepted empty arguments and inserted empty documents.

Recommended remediation: Enforce strict JSON schemas, required fields, type constraints, non-empty payloads, and authorization before mutation. Add idempotency and reject invalid writes without touching persistence.

3.7 LOW: CORS Preflight Blocked

LOW

Finding: OPTIONS /mcp reportedly returns HTTP 405, preventing browser-based clients from connecting directly under standard CORS behavior.

Recommended remediation: If browser clients are supported, implement an explicit OPTIONS handler and narrow Access-Control-Allow-Origin, methods, and headers to trusted origins. Otherwise document that browser-direct MCP clients are unsupported.

4. Comprehensive Operational Matrix (Rows 1-15)

Comprehensive operational matrix. Rows are operation entries; get_course_topic_stats is split into topic and course modes, so the matrix contains 30 rows for 29 unique tools.

No.	Tool / mode	Type	Risk	Measured latency	Class	Verified status / notes
1	get_student_profile	read	Low	150 ms	Fast	FUNCTIONAL (CRITICAL LEAK: orginalPassword).
2	get_student_enrollments	read	Low	182-699 ms	Normal (< 1s)	FUNCTIONAL. Returns courses and projects.
3	get_student_subscription	read	Low	55 ms	Fast	FUNCTIONAL. plan: free; active: false.
4	get_student_assessment_marks	read	Low	40 ms	Fast	FUNCTIONAL. Clean empty array [].
5	get_module_progress	read	Low	60 ms	Fast	FUNCTIONAL. Progress: chapter 25%, lesson 100%. Empty args reportedly leak a Python exception.
6	get_course_outline	read	Low	58 ms	Fast	FUNCTIONAL. Curriculum syllabus tree. Reportedly public without Authorization.
7	get_student_learning_context	read	Low	65 ms	Fast	FUNCTIONAL. Bloom level 1, streak 0, mastery 0.
8	get_lesson_grounding_content	read	Low	45 ms	Fast	FUNCTIONAL. Handles missing grounding gracefully; reportedly public without Authorization.
9	get_activity_grounding_material	read	Low	45 ms	Fast	FUNCTIONAL. Returns topic notes and video links; reportedly public without Authorization.
10	get_course_topic_stats (topic)	read	Low	3,429-5,624 ms	SLOW (> 2s)	FUNCTIONAL. 8 activity dimensions and cognitive analysis.
11	get_course_topic_stats (course)	read	Low	3,414 ms	SLOW (> 2s)	FUNCTIONAL. Course aggregate progress metrics.
12	update_topic_completion	write	Med	100 ms	Fast	FUNCTIONAL. Recalculates progress to 11%.
13	save_practice_activity_dataset	write	Med	55 ms	Fast	FUNCTIONAL. Validates 8 activity types.
14	save_activity_evaluation	write	Med	75 ms	Fast	FUNCTIONAL. Persists evaluation scores and earned XP; empty arguments reportedly create junk records.
15	save_learning_conversation	write	Med	50 ms	Fast	FUNCTIONAL. Persists conversation turns; empty arguments reportedly create junk records.

4. Comprehensive Operational Matrix (Rows 16-30)

Comprehensive operational matrix. Rows are operation entries; get_course_topic_stats is split into topic and course modes, so the matrix contains 30 rows for 29 unique tools.

No.	Tool / mode	Type	Risk	Measured latency	Class	Verified status / notes
16	handle_guided_learn	write	Med	60 ms	Fast	FUNCTIONAL. Persists Socratic teaching flow; empty arguments reportedly create junk records.
17	get_capstone_project_context	read	Low	55 ms	Fast	FUNCTIONAL. Returns project epics and deliverables.
18	save_capstone_viva_questions	write	Med	75 ms	Fast	FUNCTIONAL. Persists viva questions; returns attempt ID.
19	get_viva_submission	read	Low	60 ms	Fast	FUNCTIONAL. Retrieves student submission and rubrics.
20	save_viva_grade	write	Med	70 ms	Fast	FUNCTIONAL. Saves AI evaluation and question scores.
21	get_lab_context	read	Low	35 ms	Fast	FUNCTIONAL. Enforces 24-hex ObjectId validation.
22	save_lab_viva_questions	write	Med	75 ms	Fast	FUNCTIONAL. Entitlement-gated for unowned labs.
23	get_lab_viva_submission	read	Low	50 ms	Fast	FUNCTIONAL. Purchase-check enforced.
24	save_lab_viva_grade	write	Med	75 ms	Fast	FUNCTIONAL. Purchase-check enforced.
25	get_role_certprep_context	read	Low	60 ms	Fast	FUNCTIONAL. Validates role existence.
26	save_role_certprep	write	Med	210 ms	Fast	FUNCTIONAL. Multi-collection blueprint write.
27	get_certprep_module_context	read	Low	65 ms	Fast	FUNCTIONAL. Returns certification module details.
28	save_certprep_mock_exam	write	Med	40 ms	Fast	FUNCTIONAL. Validates questions; returns mock exam ID.
29	get_role_interview_prep_context	read	Low	40 ms	Fast	FUNCTIONAL. Validates role existence.
30	save_role_interview_prep	write	Med	55 ms	Fast	FUNCTIONAL. Validates topics array; returns prep ID.

5. Prioritized Engineering Action Plan

Priority	Action	Implementation detail	Validation / exit criterion
P0 - Security emergency	Rotate exposed credential	Reset the affected student account password immediately. Revoke active sessions and tokens where supported. Review authentication and profile-access logs for suspicious use.	Credential rotation recorded; sessions invalidated; log review completed; incident scope documented.
P0 - Security emergency	Remove sensitive profile fields	Use a strict allow-list response schema or projection. Exclude orginalPassword, passwordOtp, mobileOtp, linked tokens, and unnecessary PII. Hash stored passwords with Argon2id or bcrypt.	Automated contract test confirms response never includes secret fields; database check confirms passwords are hashed, not plaintext.
P1 - Performance	Index aggregation queries	Add compound indexes { student_id: 1, topic_id: 1 } and { student_id: 1, course_id: 1 } after confirming collection schemas and explain plans.	Compare explain plans and p50/p95 latency under representative data volume; verify query planner uses expected indexes.
P1 - Performance	Cache and incrementally maintain summaries	Persist activity summaries on student-topic records. Increment course completion summaries on topic completion writes rather than rescanning the full curriculum tree.	Aggregation work removed from hot read path; values reconcile with source records; invalidation/rebuild process documented.
P1 - API hardening	Harden auth and input validation	Reject query-string tokens; require Authorization: Bearer. Validate tool args, return JSON-RPC -32602 for invalid params, and reject empty write payloads.	Negative tests cover unauthenticated requests, query token rejection, missing fields, malformed types, empty mutation args, and safe errors.
P2 - Access design	Gate protected content and configure CORS	Apply entitlement checks to paid course content. If browser-origin clients are supported, implement constrained OPTIONS/CORS behavior.	Access test matrix distinguishes public syllabus from paid assets; CORS tests allow only trusted origins and needed methods/headers.

Suggested remediation sequence

1	Contain	Rotate credentials, revoke sessions, inspect logs, and temporarily restrict profile tool access if necessary.
2	Fix exposure	Deploy a safe profile response schema; confirm no secret or unrelated PII fields are serialized.
3	Harden API	Enforce bearer-only auth, argument validation, non-empty mutations, and sanitized JSON-RPC errors.
4	Optimize hot paths	Inspect query plans, add appropriate indexes, and incrementally maintain summaries.
5	Verify	Run regression, entitlement, security, load, and data-consistency tests before closing findings.

6. Architecture Note: MCP Tool Discovery

The supplied audit considers unauthenticated tools/list behavior informational and consistent with MCP client discovery, where clients initialize and retrieve tool schemas before attaching user credentials. This is acceptable only if tool execution and every data-access path enforce authentication and authorization independently. Public discovery must not imply public access to student records or mutations. Closure should require evidence that secret-field exposure is eliminated, affected credentials are rotated, access checks pass, and performance gains are measured against a reproducible baseline.